



ISC 互联网安全大会



360 互联网安全中心

勒索软件取证与溯源

山东警察学院 张璇

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

(原“中国互联网安全大会”)



特别感谢：

深信服、安天、安恒、科来、360

安徽肥西网安 佟杨

安徽铜陵网安 戴华

江苏常州网安 张充

香港大学 邹锦沛

提供样本及技术咨询

目录

- 进化中的勒索软件
- 勒索软件的生意经
- 取证溯源思路与方法
- 更多的挑战

进化中的勒索软件

中国是勒索软件威胁的重灾区。2017年，中国成为亚太区受到勒索软件影响最严重的国家。较上年全球排名16位相比，2017年中国在全球排名第2（赛门铁克第23期《互联网安全威胁报告》）。

- 勒索软件是一种通过**屏幕锁定或加密**用户有价值的文件，并要求支付赎金来解除或解密文件的恶意软件。

LOCKER|屏幕锁定器

CRYPTO|文件加密器



勒索软件在进化

● 当我们经历了Wannacry的惨痛教训，是否有所进步？2017.5-2018.9

关于在市内六区暂停受理不动产登记业务的通告

近日，因**国土资源专网**遭到“勒索”病毒攻击，全省部分地市包括我市的市区不动产登记系统受到影响，无法正常办理不动产登记业务。市不动产登记中心正在组织网络专家进行紧急抢修维护。

9月3日（周一）起，芝罘、莱山、福山、牟平、开发区、高新区六区不动产分中心暂停受理相关不动产登记业务，恢复受理时间我中心会及时通知。

请关注烟台市国土资源微信公众号、网站和烟台市不动产登记中心微信公众号。

给您带来的不便，敬请广大市民谅解。

附：

国土资源微信公众号：ytsztzyj

国土资源网站地址：www.ytgi.gov.cn

不动产登记中心资源微信公众号：ytdcdj



诸城新闻

4小时前 · 诸城新闻官方头条号

已关注

诸城不动产登记网络受勒索病毒攻击

通知

广大市民：

因不动产登记网络受勒索病毒攻击，造成不动产登记系统瘫痪，技术人员正在抢修之中，网络恢复期间不动产登记业务无法办理。诸城市政务服务中心其他业务不受影响，有业务办理需要的市民请合理安排行程。

由此给您造成的不便敬请谅解，望大家相互转告！系统恢复后我们将及时告知。

诸城市政务服务中心

诸城市国土资源局

2018年9月2日

945阅读

山东省公安厅

关于做好 GlobeImposter3.0 勒索病毒安全防护工作的紧急通知

各省直机关、事业单位和重点国有企业网络安全责任部门：

近日，我省有关行业出现内部服务器感染新型勒索病毒的情况，经分析为GlobeImposter3.0、GlobeImposter3.0勒索病毒变种或相关变种，病毒将加密后的文件重命名为**0x4444**扩展名，GlobeImposter3.0采用RSA+AES算法加密，目前该勒索病毒加密的文件暂无解密工具，在被加密的目录下会生成一个名为“HOW_TO_BACK_FILES.txt”的txt文件，显示受害者的个人ID序列号以及黑客的联系方式等。为切实做好我省党委政府网站、业务系统、电子邮件系统等关键信息基础设施运行安全和数据安全，现将有关工作要求通知如下：

一、切实做好GlobeImposter3.0勒索病毒紧急应对工作。

由于目前该勒索病毒加密后的文件暂无解密方法，接此通知后，各单位要立即采取以下措施进行应急防范：一是关闭病毒传播端口（445、3389、135、139）；二是对操作系统口令进行修改，加强口令强度和口令复杂度；三是重要业务数据、资料及时备份；四是视情对本单位网络进行断网检查，避免交叉感染；五是已将

进化中的勒索软件

● 勒索软件发展史

```
Dear Customer:

It is time to pay for your software lease from PC Cyb
Complete the INVOICE and attach payment for the lease
If you don't use the printed INVOICE, then be sure to
reference numbers below in all correspondence. In ret

- a renewal software package with easy-to-follow, con
- an automatic, self-installing diskette that anyone

Important reference numbers: A5599796-2695577-

The price of 365 user applications is US$189. The pri
lifetime of your hard disk is US$378. You must enclo
cashier's check or international money order payable
for the full amount of $189 or $378 with your order.
company, address, city, state, country, zip or postal
to PC Cyborg Corporation, P.O. Box 87-17-44, Panama 7

Press ENTER to continue
```

第一个勒索软件：1989 AIDS / PC-CYBORC

The AIDS Information Trojan from 1989:



Dear Customer:

It is time to pay for your software lease from PC Cyborg Corporation. Complete the INVOICE and attach payment for the lease option of your choice. If you don't use the printed INVOICE, then be sure to refer to the important reference numbers below in all correspondence. In return you will receive:

- a renewal software package with easy-to-follow, complete instructions;
- an automatic, self-installing diskette that anyone can apply in minutes.

Important reference numbers: A5599796-2695577-

The price of 365 user applications is US\$189. The price of a lease for the lifetime of your hard disk is US\$378. You must enclose a bankers draft, cashier's check or international money order payable to PC CYBORG CORPORATION for the full amount of \$189 or \$378 with your order. Include your name, company, address, city, state, country, zip or postal code. Mail your order to PC Cyborg Corporation, P.O. Box 87-17-44, Panama 7, Panama.

Press ENTER to continue

The 'Petya' MBR ransom trojan from 2016:

You became victim of the PETYA RANSOMWARE!

The harddisks of your computer have been encrypted with an military grade encryption algorithm. There is no way to restore your data without a special key. You can purchase this key on the darknet page shown in step 2.

To purchase your key and restore your data, please follow these three easy steps:

1. Download the Tor Browser at "<https://www.torproject.org/>". If you need help, please google for "access onion page".
2. Visit one of the following pages with the Tor Browser:

<http://petya37h5tbhyvki.onion/LqPmoG>
<http://petya5koahtsf7sv.onion/LqPmoG>

3. Enter your personal decryption code there:

cfNnLe-NpzKq3-Bxxunx-hHRRko-KEJU6-4np3Jo-Eei8Ut-vTe6N2-tzbCAQ-gqNim5-99z8RA-2nnvBq-pAPmsz-n99WQm-fUFT1i

If you already purchased your key, please enter it below.

Key:

● 勒索软件发展史

2012 Reveton

The Grand Jury charges that:

GENERAL ALLEGATIONS

At all times material to this Indictment:

1. “Ransomware” refers to a type of malicious computer software that extorts money from victims. Generally, once ransomware infects a victim’s computer, it “locks” the computer so that the computer’s users cannot access any data. The ransomware then often displays a message on the screen, referred to as a “splash screen,” with instructions for paying a ransom. The instructions promise, sometimes falsely, that users will regain access to their data upon payment of the ransom.
2. Reveton was a type of ransomware that infected computers throughout the United States and other countries. When Reveton infected a victim’s computer, it would display a splash screen that included the logo of a law enforcement organization and a message falsely informing the victim that the law enforcement organization had found illegal material on the infected



前微软网络工程师Raymond Odigie Uadiale于2018年4月被起诉，承认与勒索软件有关的洗钱行为，被判18个月监禁

- 勒索软件发展史

2013

改变游戏规则CryptoLocker

- 钓鱼邮件传播.
- 要求72 小时支付比特币
- 感染50万台, 1.3% 进行了支付
- 估计勒索金额\$27M



进化中的勒索软件



ISC 互联网安全大会



360 互联网安全中心

● 勒索软件发展史

2017

重型武器 Wannacry

关键词：永恒之蓝/MS17-010/445

我入队民警首先的执法行为。

4、勒索病毒证明2份，证明因勒索病毒之无法预见因素造成我大队存储的截至2017年5月12日之前的执法视频全部消灭之事实。

班玛扎西交通肇事罪一案

判决 判决

一审

法院观点 勒索病毒 | 1

由于取证程序不规范，应作为非法证据予以排除的辩护意见，公诉人提交的天峻县公安交通警察大队《情况说明》表述“2017年5月12日执法记录仪采集终端被勒索病毒攻击，导致上传的班玛扎西提取血液视频无法正常播放，经专业人员破解也无法恢复该视频”，鉴于此由于不能排除血液提取过程是否规范的合理怀疑，故对被告人班玛扎西血液中血醇浓度为232

一审

结果命中 勒索病毒 | 1

4时使用的水果刀。 15、闻喜县公安局110指挥中心情况说明，主要内容：2017年5月14日，王彬杀人案当天闻喜县公安局110接警系统被全国比特币勒索病毒侵入，导致110接处警系统和录音系统瘫痪，当天所有报警记录没有音频资料。 16、文水县公安局胡兰派出所证明，主要内容：经查询，该辖区居民王彬无违法犯罪前科。

本案进程

ZE

● 公诉
2017.09.06

● 一审
2017.12.18

检

 Taiwan Semiconductor Manufacturing Company Limited

A A 品 PRINT

f p t g

台積公司公布電腦病毒感染事件影響

發佈單位：台灣積體電路製造股份有限公司
發佈日期：2018/08/05

台灣積體電路製造股份有限公司今（5）日針對電腦病毒感染事件提供進一步說明，台積公司於8月3日傍晚受到電腦病毒感染，影響台灣廠區部分電腦系統及廠房機台，受病毒感染程度因工廠而異，台積公司已經控制此病毒感染範圍，同時找到解決方案，至台灣時間下午兩點為止，約80%受影響的機台已經恢復正常，台積公司預計在8月6日前，所有受影響機台皆能夠恢復正常。

台積公司預估此次病毒感染事件將導致晶圓出貨延遲以及成本增加，對台積公司第三季的營收影響約為百分之三，毛利率的影響約為一個百分點。台積公司有信心第三季晶圓出貨延遲數量將於第四季補回，全年業績展望以美元計仍將維持7月19日所說的高個位數成長。

台積公司多數客戶皆已收到相關事件的通知，我們也正與客戶緊密合作，溝通其晶圓交貨時程，台積公司將在未來幾天內與個別客戶溝通細節資訊。

此次病毒感染的原因為新機台在安裝軟體的過程中操作失誤，因此病毒在新機台連接到公司內部電腦網路時發生病毒擴散的情況。惟台積公司資料的完整性和機密資訊皆未受到影響，台積公司已採取措施彌補此安全問題，同時將進一步加強資訊安全措施。

公司發言人
Lora Ho
Senior Vice President & Chief Financial Officer & Spokesperson
電話：886-3-5054602

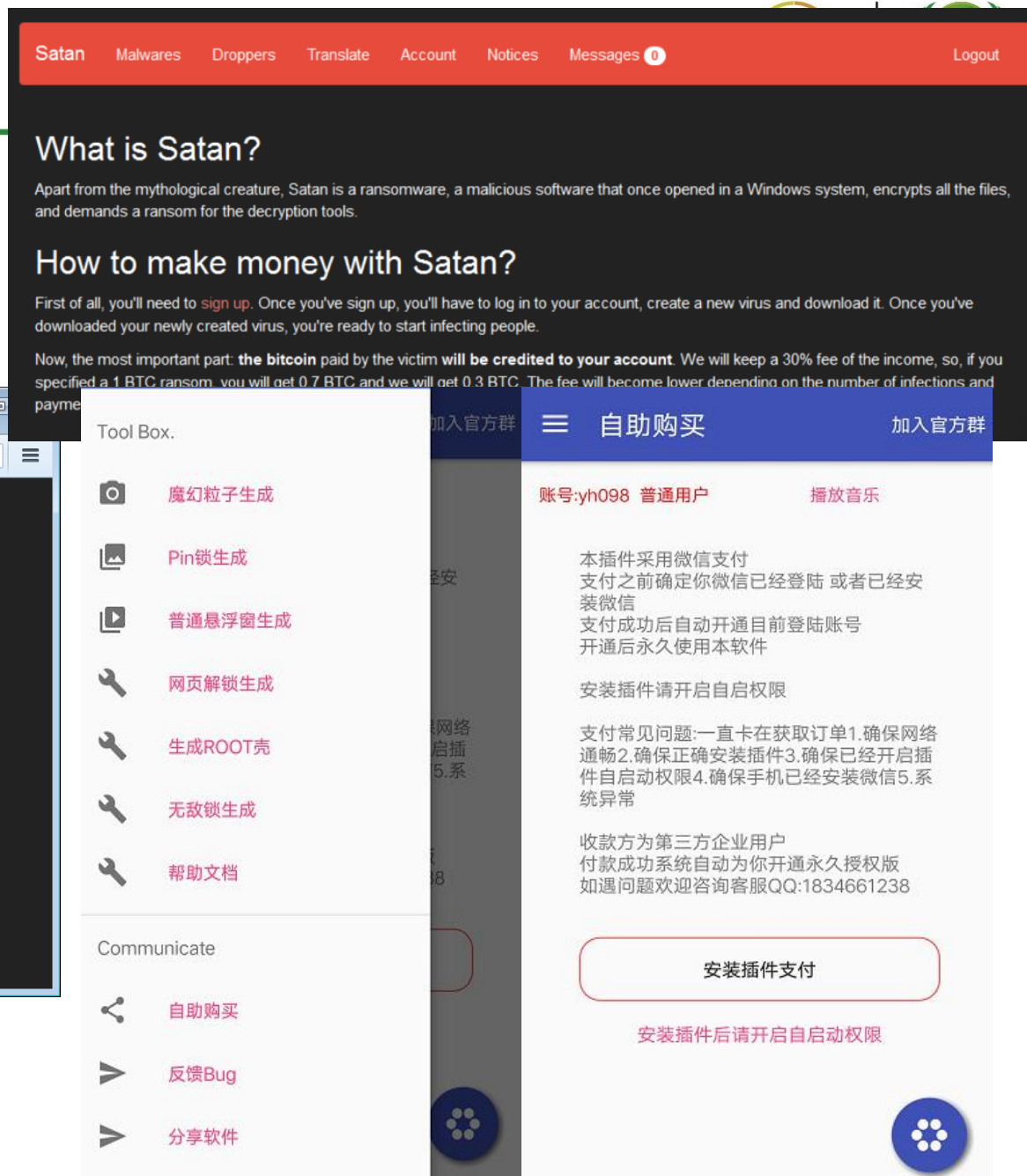
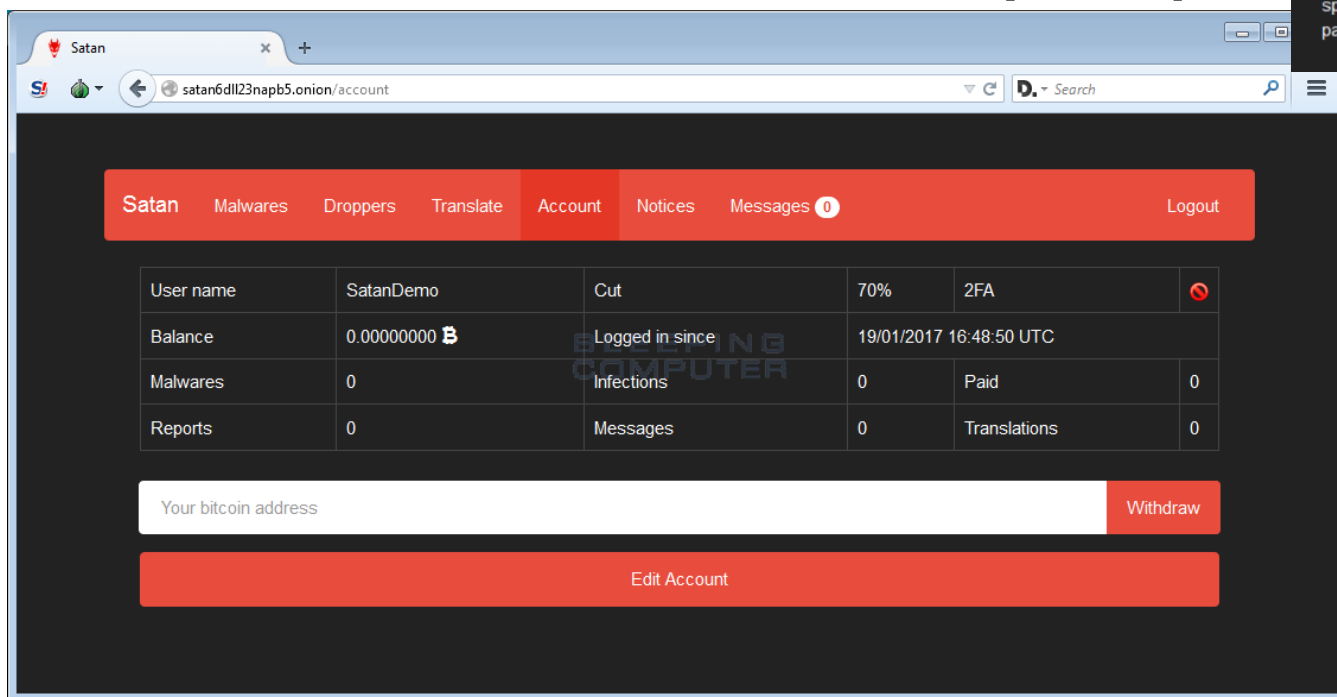
公司代理發言人
Elizabeth Sun
Senior Director, TSMC Corporate Communications Division
電話：886-3-5682085

没打补丁，没关端口，台积电因本次事件损失1.7亿美元左右，约合人民币11.5亿元

进化中的勒索软件

● 勒索软件发展史

Ransomware-as-a-Service (RaaS)



进化中的勒索软件

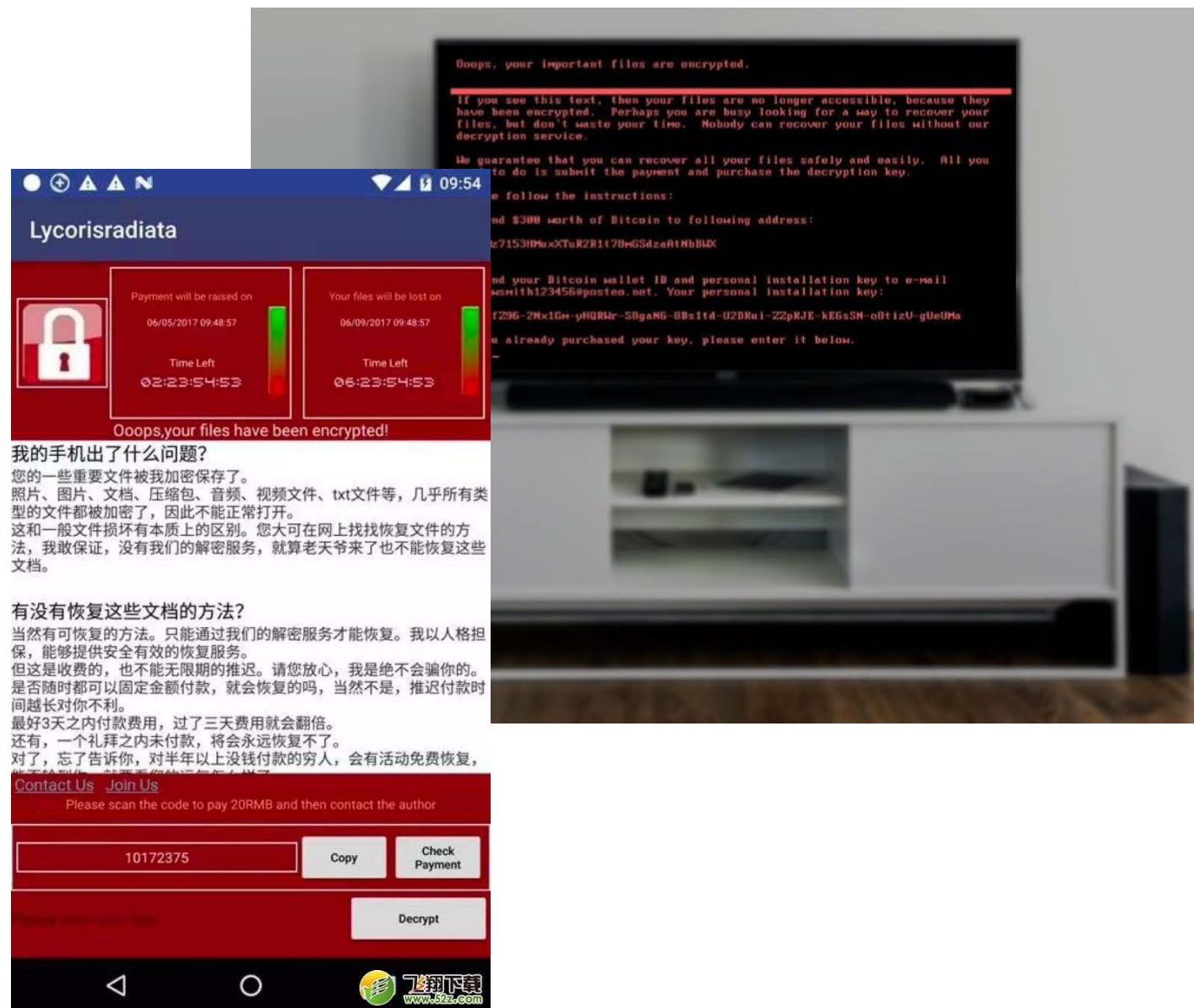
● 勒索软件的未来？

● 影响面更广：

移动端
工控系统
IOT设备

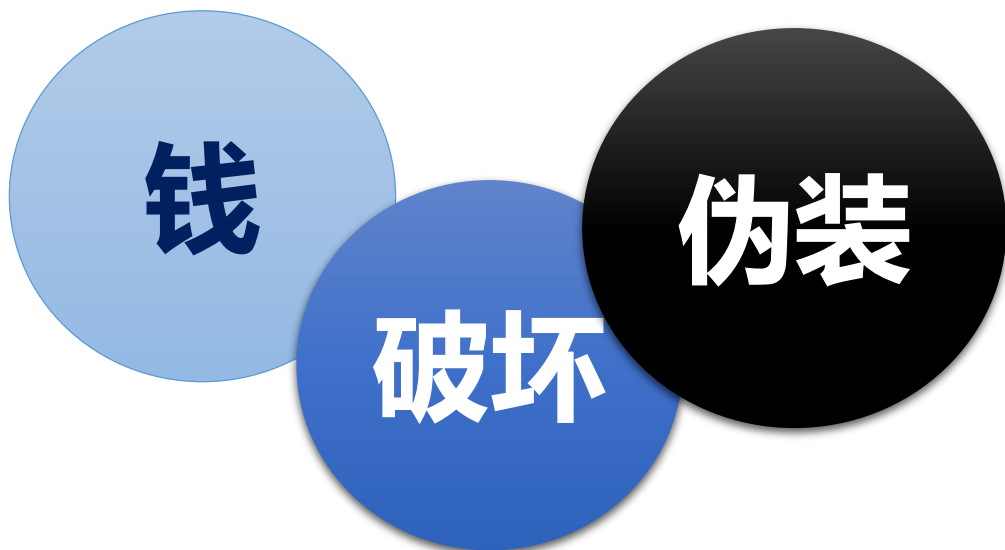
● 危害更大：

定点投放针对性强
其他犯罪的合流
暗网、加密数字货币难以追溯



勒索软件的生意经

● 他们要什么？



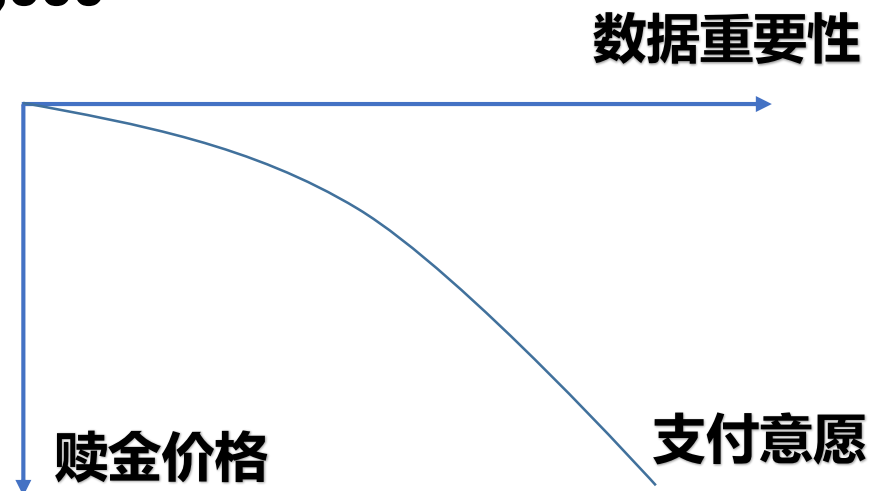
- 好莱坞长老会医疗中心支付40比特币
- 马萨诸塞州特沃斯伯警察部门在FBI的帮助下，支付了500美元
- 马萨诸塞州斯旺西警察部门决定支付2比特币的赎金
- 卡尔加里大学支付2万美元来恢复电子邮件系统

...

IBM security:

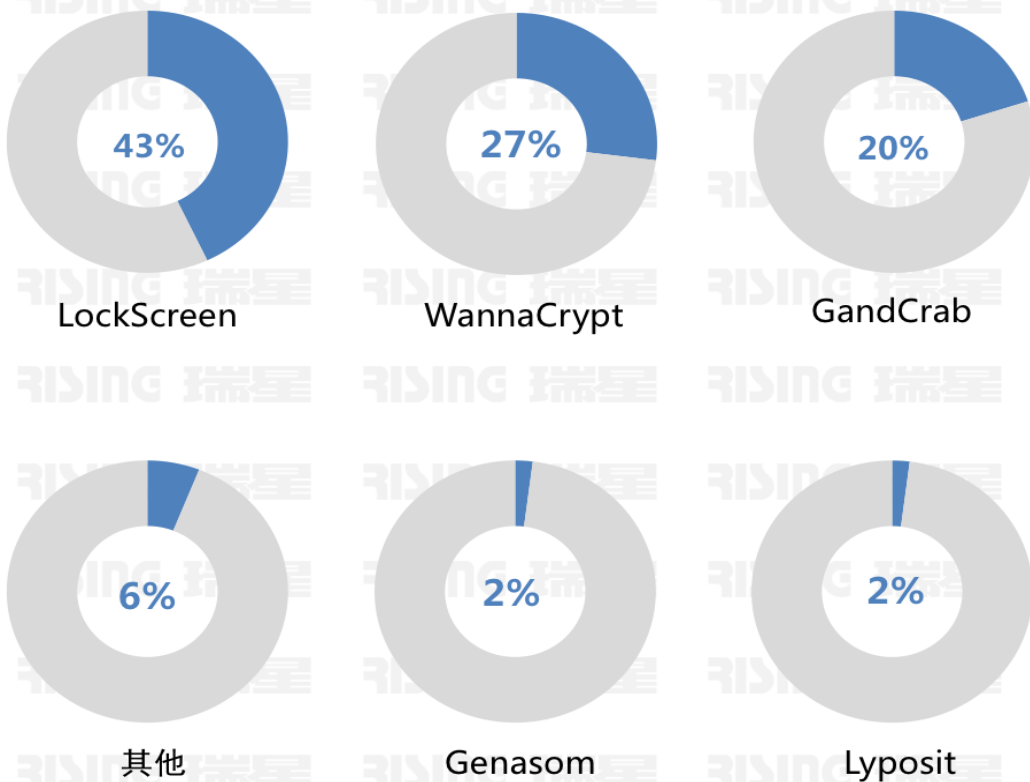
70% of business victims paid

Of those, 50% paid more than \$10,000, 20% more than \$40,000



● 常见勒索软件家族

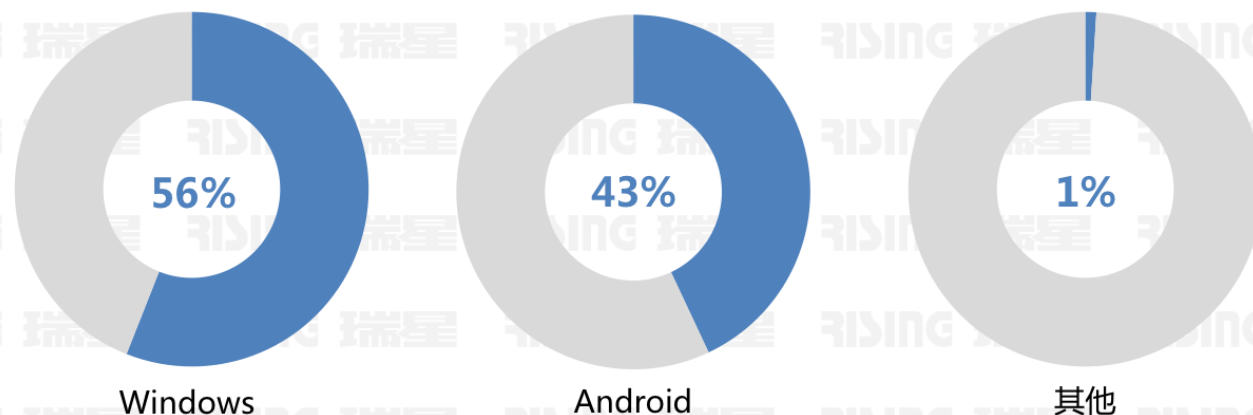
2018年1至6月勒索软件按家族分类



瑞星：2018年上半年中国网络安全报告

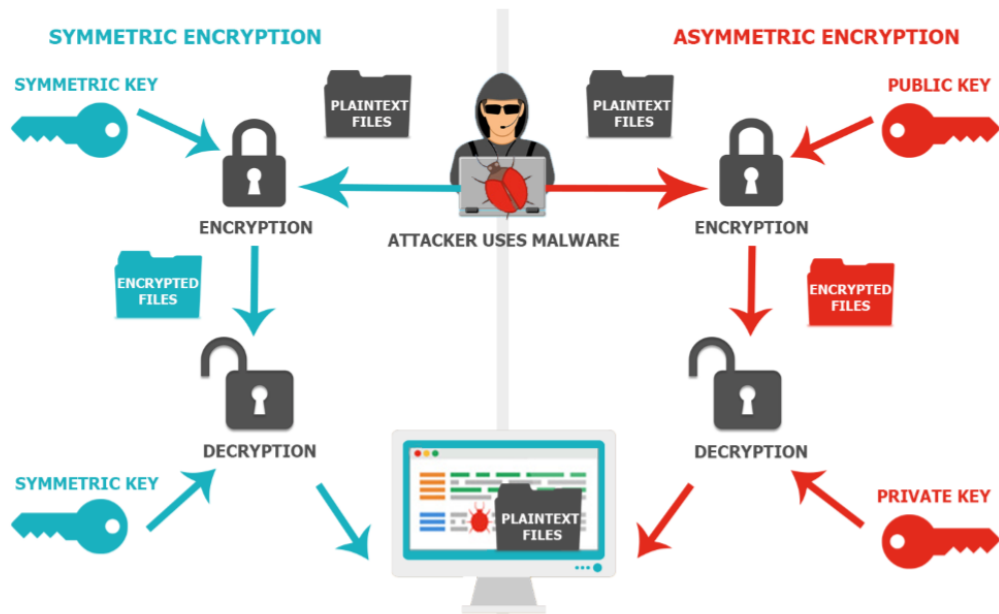
通过对瑞星捕获的勒索样本按家族分析发现，LockScreen家族占比43%，位列第一，其次为WannaCrypt占比27%，以及GandCrab占比20%。

2018年1至6月勒索软件按平台分类



● Crypto Ransomware框架





对称密钥加密vs.非对称密钥加密

对称密钥加密

AES (128 to 256 bit key), 3DES, DES

非对称密钥加密

RSA, Elliptic Curve Cryptography (ECC)

➤ 加密数据文件，允许系统基本操作

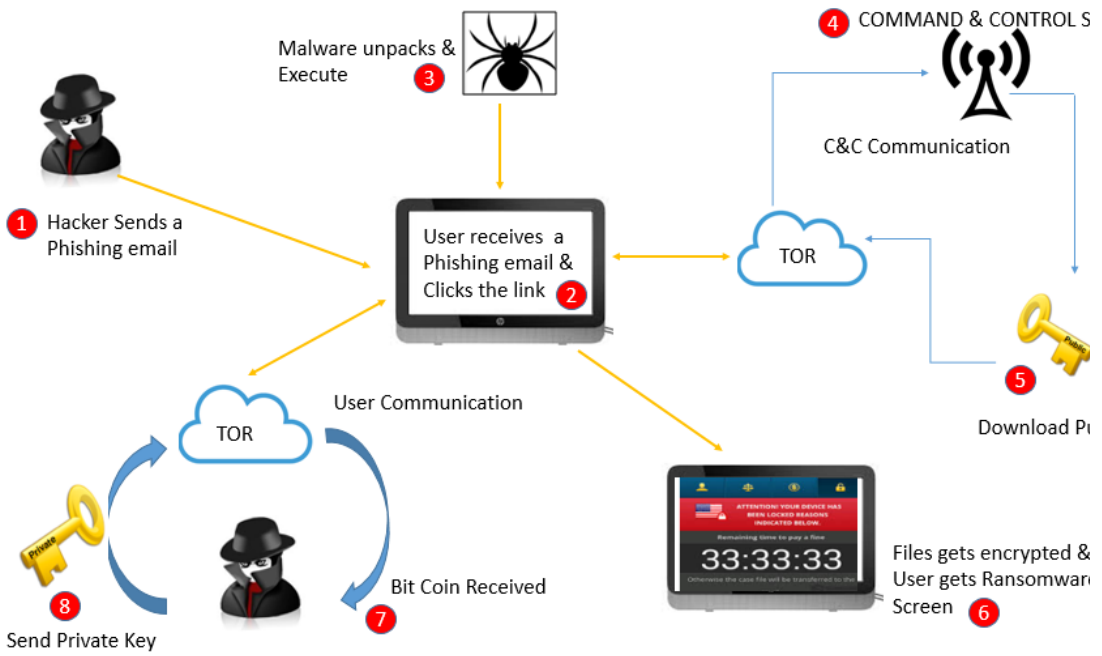
- Microsoft Office files (.doc, .docx, .xls, .xlsx, .ppt, .pptx, .rtf)
- Open Office files (.odt, .ods, .odp)
- Adobe PDF files
- Popular image files (.JPG, .PNG, raw camera files, etc.)
- Text files (.txt, .RTF, etc.)
- Database file (.sql, .dba, .mdb, .odb, .db3, .sqlite3, etc.)
- Compressed file (.zip, .rar, .7z, etc.)
- Mail files (.pst)
- Key files (.pem, .crt, etc.)

➤ 加密系统文件或磁盘

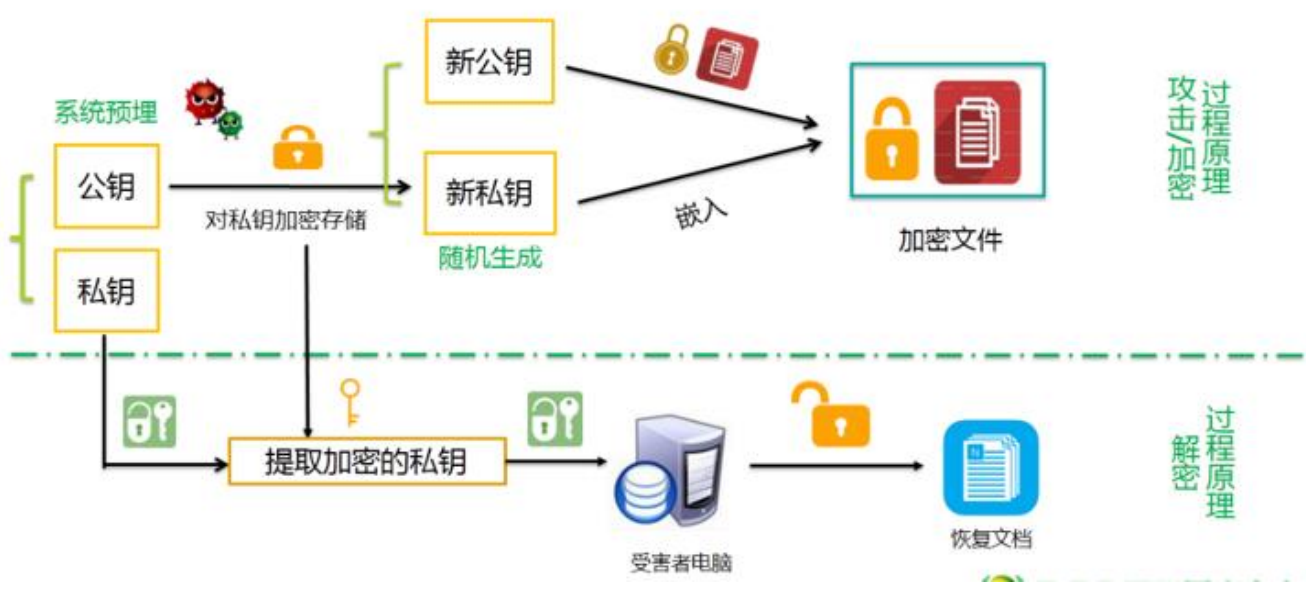
Petya:

加密MBR主引导记录
无法启动

目标的价值 Command and Control server (C&C) 突破隔离网支付勒索费用的限制



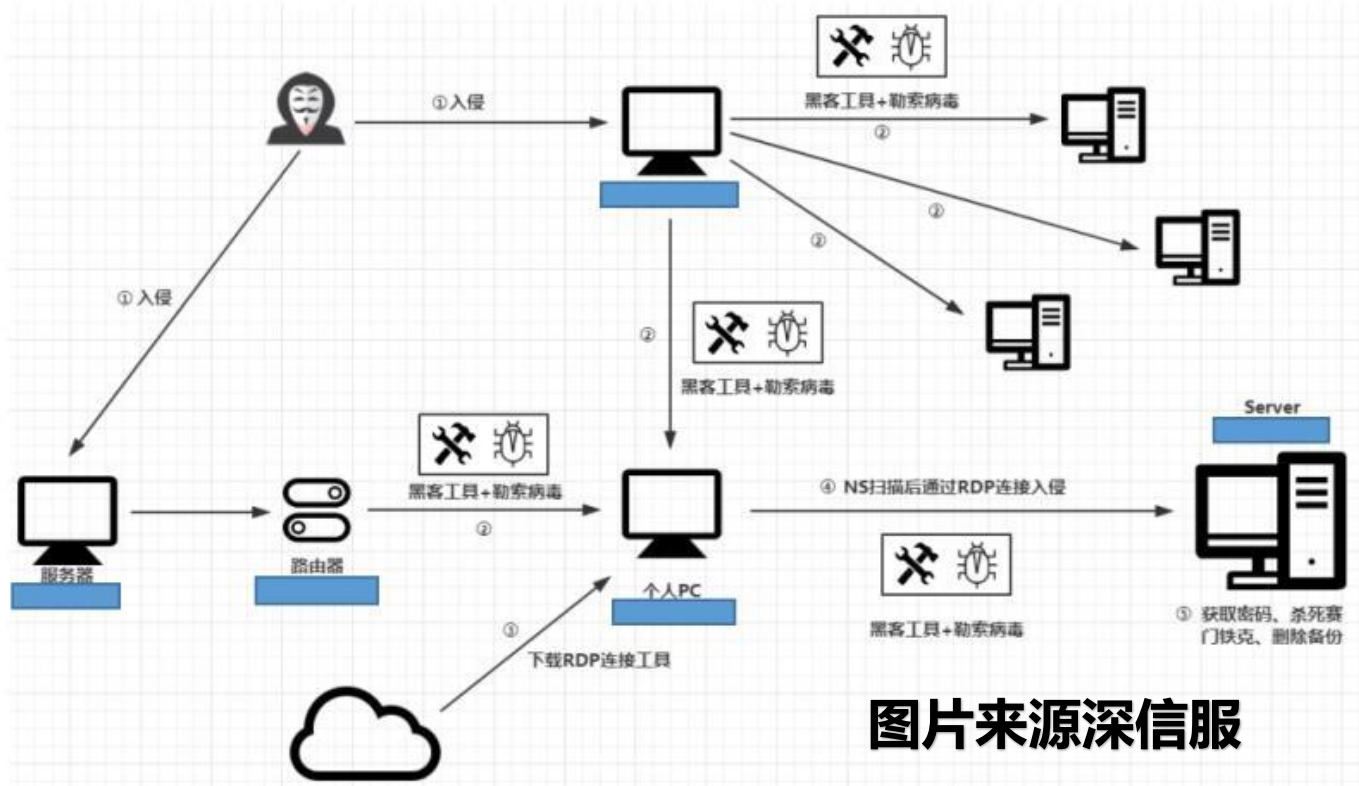
有C&C模式



无C&C模式

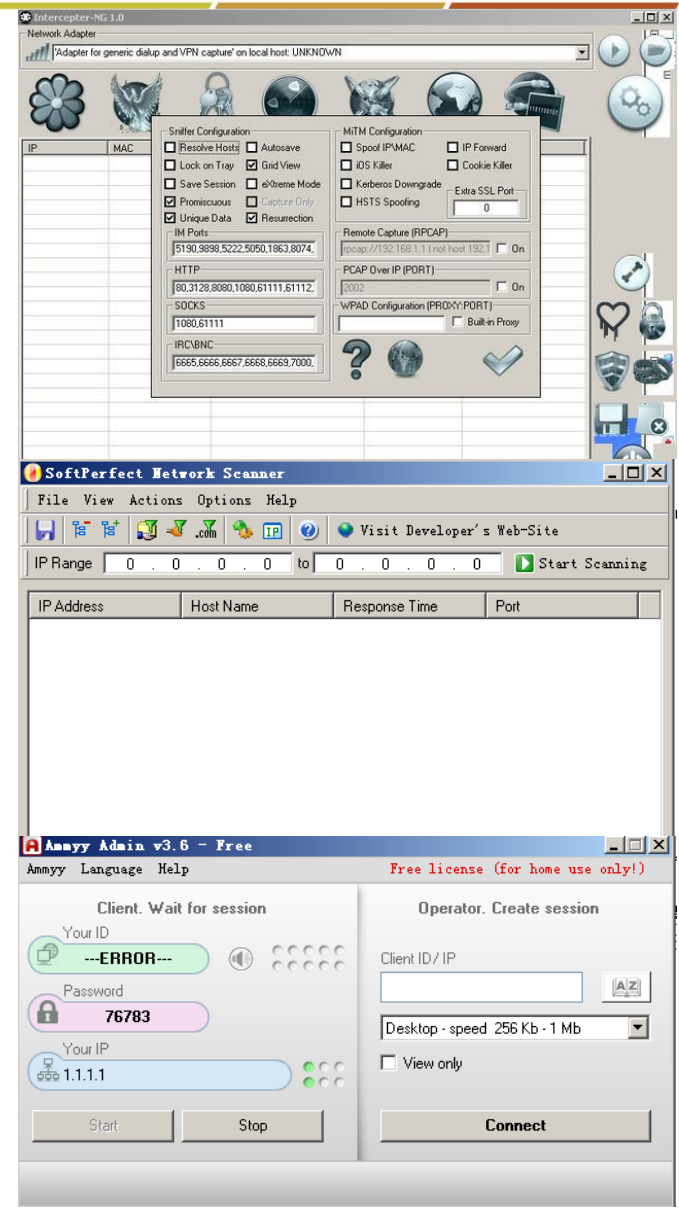
目标的价值

传播感染使用多种黑客工具定点渗透



图片来源深信服

内网扫描&爆破工具：Interceptor-NG、NetworkShare
远控工具：AA_v3等
其他渗透攻击手段

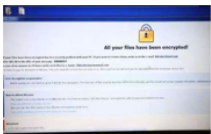


被加密的数据能恢复吗？？？

几种情况有可能：

- 逆向分析勒索软件执行上的逻辑漏洞，根据漏洞获得加密密钥或者跳过密钥直接解密文档
- 勒索软件保存密钥的服务器被安全厂商反制
- 解密密钥被其他竞争对手泄露或是勒索软件作者主动将密钥交出
- 勒索软件加密算法复杂程度较低被破解
- 密钥在上传的过程中没有使用加密的通讯协议，被技术人员截获解密密钥
- 勒索软件可能存在环境兼容问题，没有正常运行，可尝试进行数据恢复
- 例如Wannacry Satan等

勒索病毒解密工具_已开发勒索病毒解密工具工具



已开发勒索病毒解密工具工具,支持SQL数据库 mysql ora等数据库,专业解密恢复支持提取表数据,支持做好数据库直接用.
www.sql110.com 2018-08 ▼ V3 - 评价 - 广告

勒索病毒解密_数据解密_sql_修复_成功收费_24H服务



专业病毒解密勒索病毒解密 sql数据库修复,可解各种后缀病毒及变种,免费检测样本,速度快,大量解密案例,行业良心价格,24H服务,成功收费,先签合同,再恢复,开正规发票!
www.cndr.cn 2018-08 ▼ V3 - 评价 - 广告

随后她又某购物网站上搜索到了声称“可以恢复文件”的某“科技公司”，在杨桦报了文件后缀名和需要恢复文档的数量后，对方声称“可以恢复”并报出了1120元的价格，尽管价格不菲，但仍比勒索者开出的300元美金便宜，杨桦于是购买了此次服务。谁知对方不仅没有交还恢复的文档，反而向杨桦索要支付软件用户民等私人信息，称用于“验证”。“我当时觉得情况不对，拒绝了这个要求。”杨桦回忆，此后对方并没能如约恢复文件，并一直怪杨桦没有提供“验证方式”拒绝退款。直到杨桦表示申请网站维权后，对方才退还了钱款。

付钱不靠谱，那么免费总没有损失吧？杨桦还真找到一款“恢复软件”。然而下载安装后，除了跳出各类游戏广告，被加密的文件依然无法打开。

帮凶
骗子
奇才？

数据恢复合同		
甲方：上海[]科技股份有限公司	联系人：[]	电话：[]
统一社会信用代码：[]	地址：中国（上海）自由贸易试验区[]	
乙方：深圳市宝安区福永正源计算机服务中心	合同编号：20180420-05	
甲方委托乙方进行数据恢复，乙方检测甲方计算机数据结果： 1、恢复甲方中毒服务器一台。 2、电脑数据文件都被勒索病毒加密，应用软件无法打开读取。 3、需要恢复的加密文件特征：文件名添加 .ml8y3后缀 4、数据可成功恢复，文件数量恢复成功率在97%-100%。		
恢复数据方案：	方案内容	恢复费用：
通过远程协助或乙方服务器平台恢复数据	1、恢复数据前，甲方需对将要恢复的数据进行异地备份。 2、甲方承诺不对加密文件进行任何的修改。 3、数据恢复完成，甲方远程到乙方电脑验证数据是否成功，并，开票内容：计算机数据恢复服务费 4、验证成功并付款后，乙方发送数据给甲方或远程操作恢复	[]
恢复成功率：97%-100%	工期：1-3天	
甲方签字确认：	人民币大写：[]	
交易流程： 1、建立文件解密紧急救援工作组：乙方工程师团队与甲方联系人，甲方计算机维护人员、甲方软件商技术支持人员等组成救援工作组，相互配合，协商处理及数据的验证。 2、签订合同：双方加盖公章签字，通过快递合同或扫描及拍照的图片格式合同，双方确认具有法律效力。 3、付款方式： 淘宝担保交易付款：通过乙方淘宝店铺：“正源科技”拍商品并全额付款。		

- **预处理：及时断网隔离，不断电，确保勒索软件不再传播**

现场勘验环节

1. 了解基本案情和现场环境；
2. 对有关责任人和管理、技术人员做好询问笔录，了解技术细节

受害单位类型：

规模：

估算造成的损失：

中毒终端类型、用途：

拓扑图：

发现中毒时间：

中毒前有无异常

3. 查看当前进程和网络连接；
4. 抓取网络数据包；
5. 提取服务器内存镜像文件和硬盘镜像文件；

公司规模： 200人

损失无法估量

服务器用途： 金蝶财务软件服务器内网部署，与财务部门同网段，仅财务部可访问

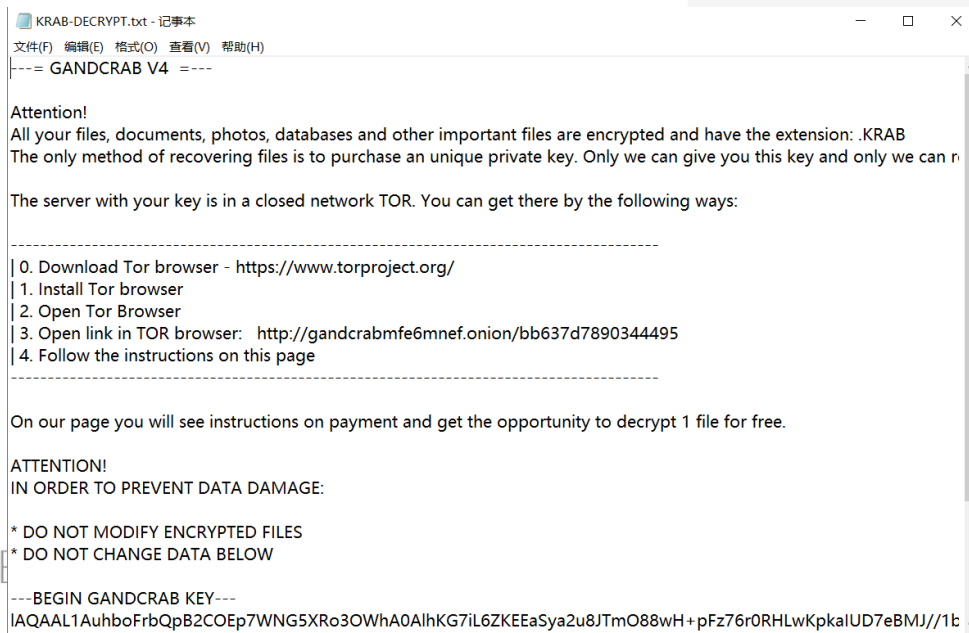
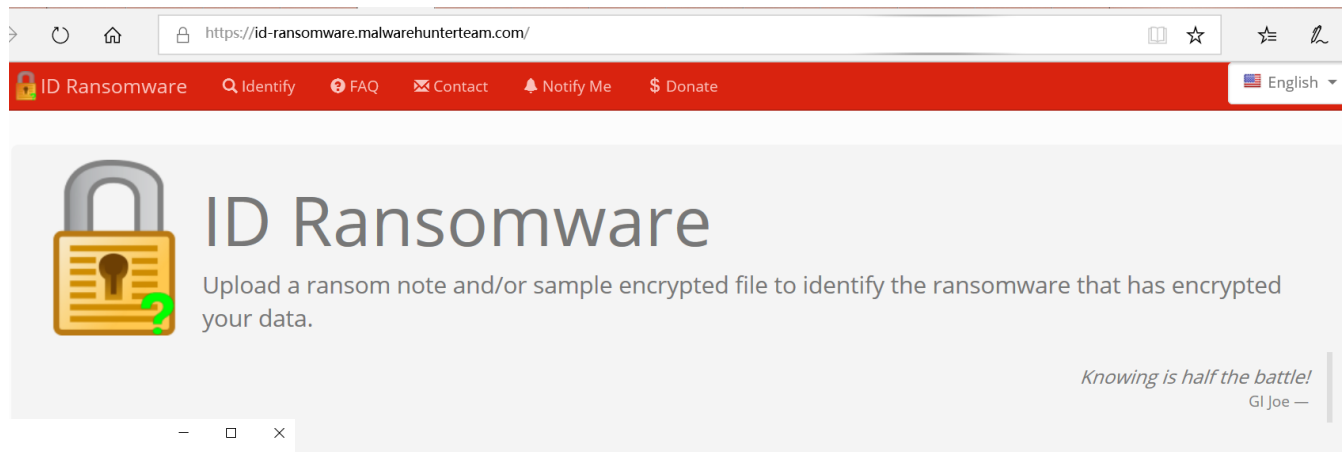
中毒时间：7月9日

中毒前未发现异常

取证要点

1.明确勒索病毒种类，分析恶意行为

- 搜索引擎搜索扩展名
- 上传至专门网站识别勒索软件
- 根据勒索信息提示判断
- 识别勒索软件可执行文件
- 确定初始感染载体



取证要点

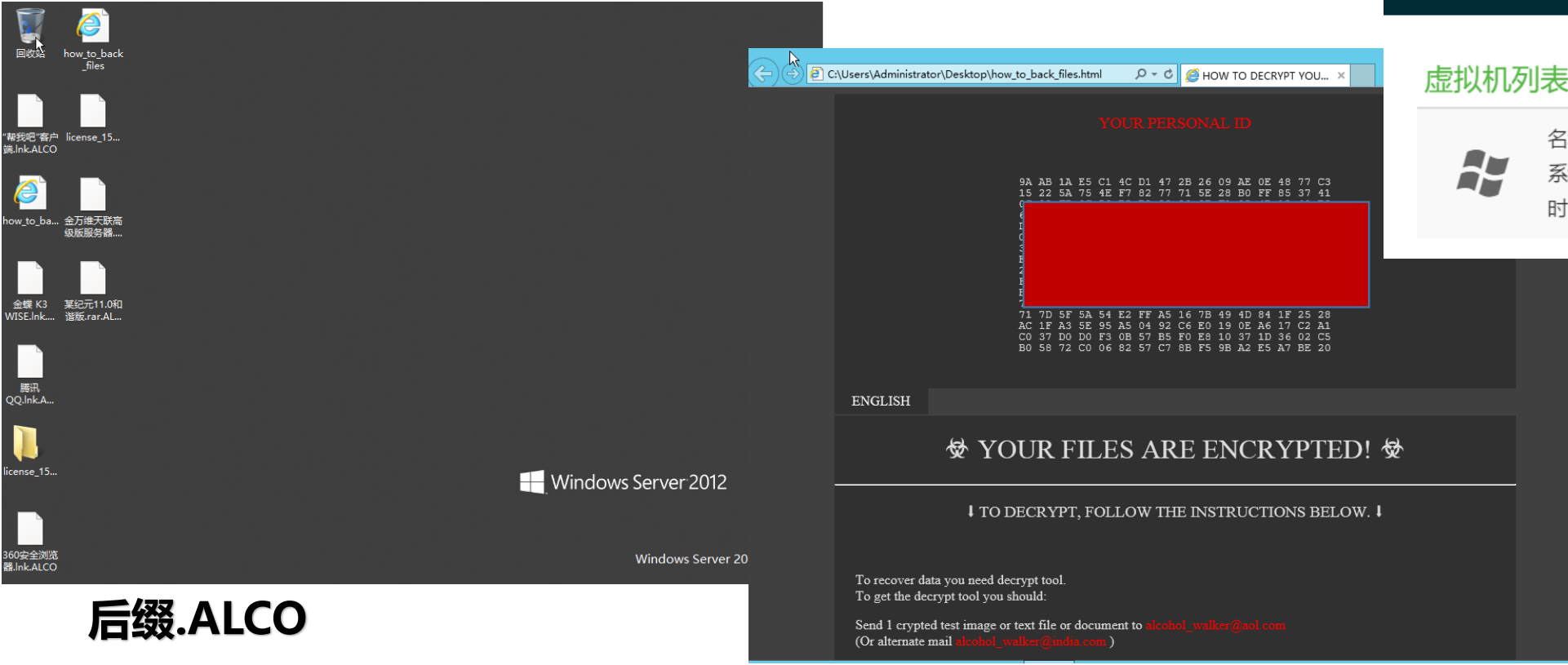
1.明确勒索病毒种类，分析恶意行为



虚拟机列表

	名称: www
	系统: Windows Server 2012 x64
	时间: 2018-08-30 22:00:02

弘连



后缀.ALCO

取证要点

1.明确勒索病毒种类，分析恶意行为

过滤 Local

高级过滤

序号	文件名	文件扩展名	逻辑大小(字节)	访问时间	创建时间	修改时间	删除时间
1	alco.exe	exe	55,296	2018-07-08 10:16:03	2018-07-08 10:16:03	2018-06-04 2...	
2	Application Data		48	2017-10-30 11:53:29	2017-10-30 11:53:29	2017-10-30 1...	
3	CEF		256	2017-11-09 12:28:44	2017-11-09 12:28:44	2017-11-09 1...	
4	History		48	2017-10-30 11:53:29	2017-10-30 11:53:29	2017-10-30 1...	
5	how_to_back_file...	html	5,536	2018-07-08 10:18:15	2018-07-08 10:18:15	2018-07-08 1...	
6	IconCache.db	db	118,651	2018-07-11 11:37:15	2018-07-11 11:37:15	2018-07-12 1...	
7	IconCache.db.AL	ALCO	76,838	2017-10-30 12:09:01	2017-10-30 12:09:01	2018-07-08 1...	
8	Microsoft		4,096	2017-11-06 15:28:00	2017-10-30 11:53:29	2017-11-06 1...	
9	Microsoft Help		48	2017-11-06 14:58:49	2017-11-06 14:58:49	2017-11-06 1...	
10	Microsoft_Corpo...		4,096	2017-11-06 14:54:41	2017-10-30 11:55:10	2017-11-06 1...	
11	Programs		144	2017-10-30 11:54:43	2017-10-30 11:54:43	2017-10-30 1...	
12	Temp		2,102	2018-07-12 16:23:37	2017-10-30 11:53:29	2018-07-12 1...	
13	Temporary Inter...						

计算机 > 本地磁盘 (C:) > Users > Administrator > AppData > Local >

- 初始化过程中，检查是否具有%appdata%环境变量，如果存在则拷贝当前运行的病毒文件至%appdata%目录下，并设置注册表实现开机启动

收藏夹

库

视频

图片

文档

音乐

计算机

本地磁盘 (C:)

新加卷 (D:)

新加卷 (F:)

网络

名称	修改日期	类型	大小
CEF	2017/11/9 12:28	文件夹	
Microsoft	2017/11/6 15:28	文件夹	
Microsoft Help	2017/11/6 14:58	文件夹	
Microsoft_Corporation	2017/11/6 14:54	文件夹	
Programs	2017/10/30 11:54	文件夹	
Temp	2018/9/5 23:45	文件夹	
Tencent	2017/11/9 12:28	文件夹	
alco.exe	2018/6/4 21:22	应用程序	54 KB
how_to_back_files.html	2018/7/8 10:18	HTML 文档	6 KB
IconCache.db	2018/7/12 11:07	Data Base File	116 KB
IconCache.db.ALCO	2018/7/8 10:18	ALCO 文件	76 KB

取证溯源思路与方法



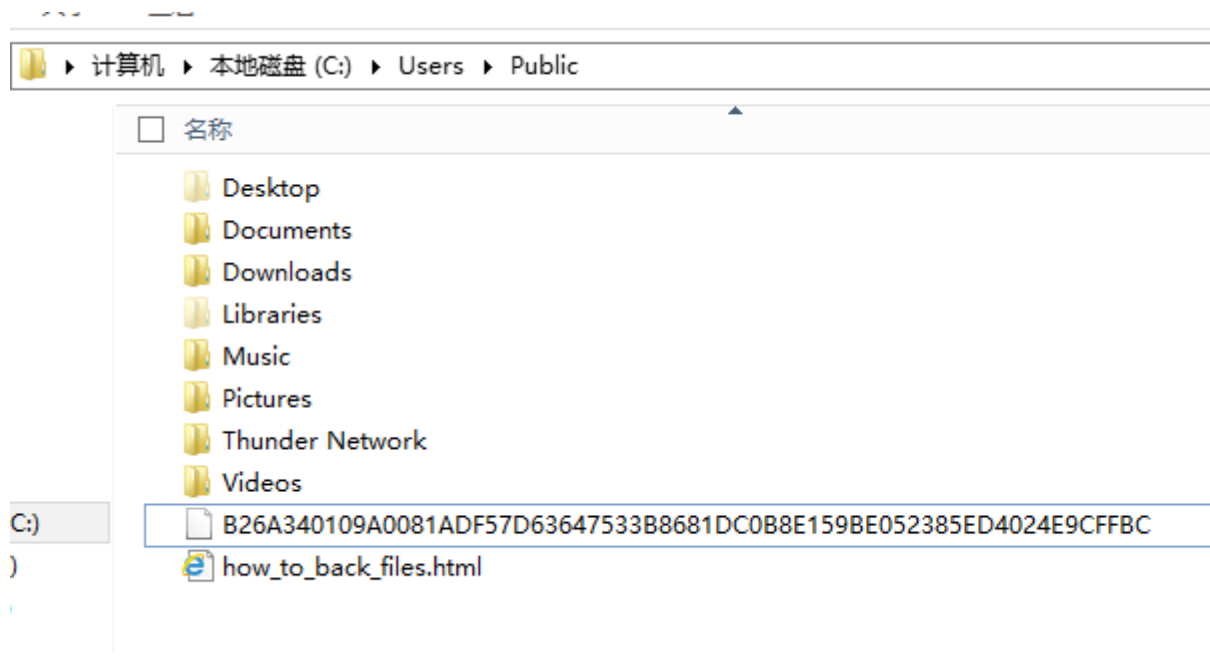
ISC 互联网安全大会



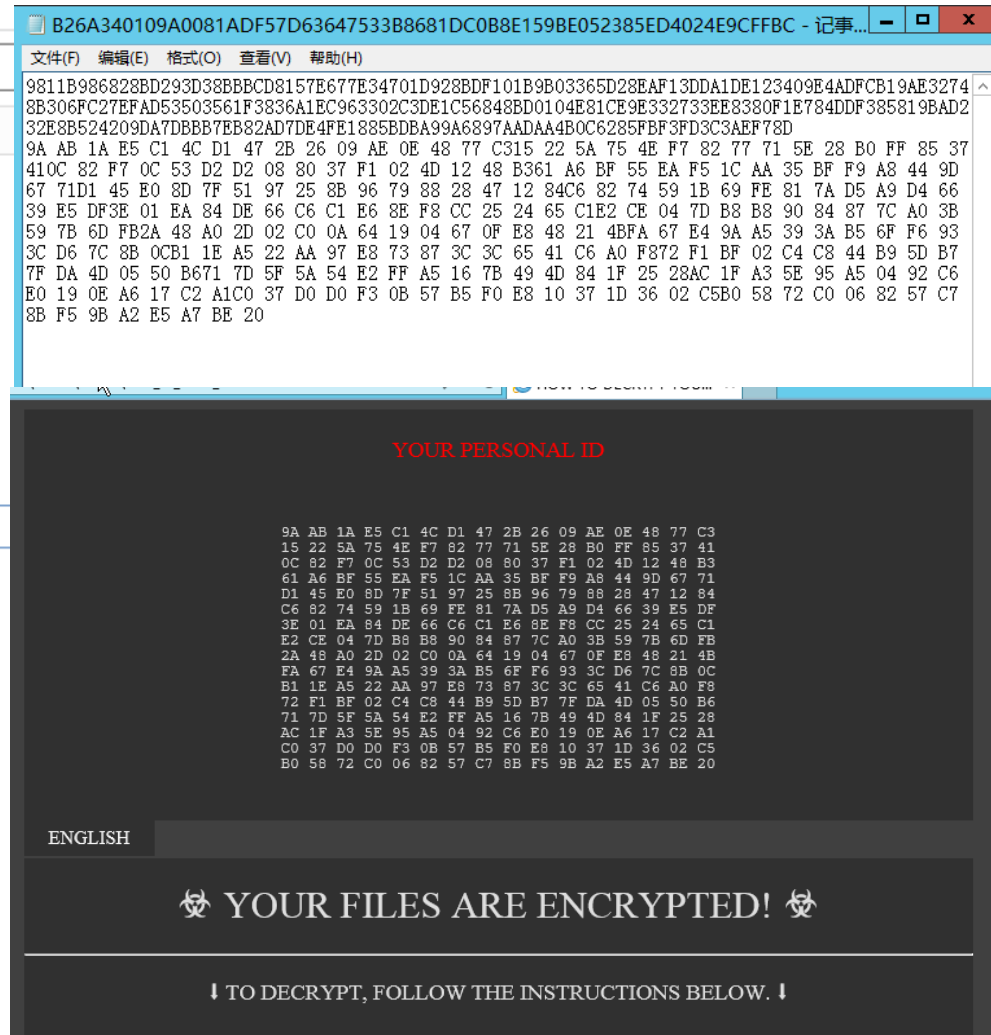
360 互联网安全中心

取证要点

1.明确勒索病毒种类，分析恶意行为



- 设置好开机启动后，生成RSA私钥并使用硬编码公钥加密，完成操作后将密钥信息以文件形式保存在%public%或者%ALLUSERSPROFILE%目录下



取证要点

1.明确勒索病毒种类，分析恶意行为

摘要	文本	十六进制	预览	磁盘视图
00001420	58 79 A2 1C D5 DB 23 5B 80 E7 CB 8F BB F1 6D 22 22 0F B8 B4 73 5B 7D 2C AD 39 8A A4 E3 41 1E F9 Xy....#[.....m""...s[{}.,9...A..			
00001440	56 31 46 D7 7A EB 0A F5 DC 2B 92 08 B5 B2 28 CC 6D 93 78 2C F1 08 41 05 C5 65 E1 F6 50 ED 51 1A VIF.z....+....(.m.x,..A..e..P.Q.			
00001460	CF E1 E8 5A 70 06 D2 6B 49 4A E1 EA 6C 12 C7 F0 5D 9B 16 72 86 BD C5 12 B6 C7 2F 03 33 6B 03 58 ...Zp..kIJ..l...].r...../.3k.X			
00001480	8B 12 67 B0 42 07 93 CD 38 09 FC FE AB 48 6D 02 83 69 F7 6A 42 B5 70 9C F9 7B DE 29 E9 48 EB 75 ...g B...C...W...4 2B 2...1..."			
000014A0	39 41 20 41 42 20 31 41 20 45 35 20 43 31 20 34 43 20 44 31 20 34 37 20 32 42 20 32 36 20 30 39 9A AB 1A E5 C1 4C D1 47 2B 26 09			
000014C0	20 41 45 20 30 45 20 34 38 20 37 37 20 43 33 0A 31 35 20 32 32 20 35 41 20 37 35 20 34 45 20 46 AE 0E 48 77 C3.15 22 5A 75 4E F			
000014E0	37 20 38 32 20 37 37 20 37 31 20 35 45 20 32 38 20 42 30 20 46 46 20 38 35 20 33 37 20 34 31 0A 7 82 77 71 5E 28 B0 FF 85 37 41.			
00001500	30 43 20 38 32 20 46 37 20 30 43 20 35 33 20 44 32 20 44 32 20 30 38 20 38 30 20 33 37 20 46 31 0C 82 F7 0C 53 D2 D2 08 80 37 F1			
00001520	20 30 32 20 34 44 20 31 32 20 34 38 20 42 33 0A 36 31 20 41 36 20 42 46 20 35 35 20 45 41 20 46 02 4D 12 48 B3.61 A6 BF 55 EA F			
00001540	35 20 31 43 20 41 41 20 33 35 20 42 46 20 46 39 20 41 38 20 34 34 20 39 44 20 36 37 20 37 31 0A 5 1C AA 35 BF F9 A8 44 9D 67 71.			
00001560	44 31 20 34 35 20 45 30 20 38 44 20 37 46 20 35 31 20 39 37 20 32 35 20 38 42 20 39 36 20 37 39 D1 45 E0 8D 7F 51 97 25 8B 96 79			
00001580	20 38 38 20 32 38 20 34 37 20 31 32 20 38 34 0A 43 36 20 38 32 20 37 34 20 35 39 20 31 42 20 36 88 28 47 12 84.C6 82 74 59 1B 6			
000015A0	39 20 46 45 20 38 31 20 37 41 20 44 35 20 41 39 20 44 34 20 36 36 20 33 39 20 45 35 20 44 46 0A 9 FE 81 7A D5 A9 D4 66 39 E5 DF.			
000015C0	33 45 20 30 31 20 45 41 20 38 34 20 44 45 20 36 36 20 43 36 20 43 31 20 45 36 20 38 45 20 46 38 3E 01 EA 84 DE 66 C6 C1 E6 8E F8			
000015E0	20 43 43 20 32 35 20 32 34 20 36 35 20 43 31 0A 45 32 20 43 45 20 30 34 20 37 44 20 42 38 20 42 CC 25 24 65 C1.E2 CE 04 7D B8 B			
00001600	38 20 39 30 20 38 34 20 38 37 20 37 43 20 41 30 20 33 42 20 35 39 20 37 42 20 36 44 20 46 42 0A 8 90 84 87 7C A0 3B 59 7B 6D FB.			
00001620	32 41 20 34 38 20 41 30 20 32 44 20 30 32 20 43 30 20 30 41 20 36 34 20 31 39 20 30 34 20 36 37 2A 48 A0 2D 02 C0 0A 64 19 04 67			
00001640	20 30 46 20 45 38 20 34 38 20 32 31 20 34 42 0A 46 41 20 36 37 20 45 34 20 39 41 20 41 35 20 33 0F E8 48 21 4B.FA 67 E4 9A A5 3			
00001660	39 20 33 41 20 42 35 20 36 46 20 46 36 20 39 33 20 33 43 20 44 36 20 37 43 20 38 42 20 30 43 0A 9 3A B5 6F F6 93 3C D6 7C 8B 0C.			
00001680	42 31 20 31 45 20 41 35 20 32 32 20 41 41 20 39 37 20 45 38 20 37 33 20 38 37 20 33 43 20 33 43 B1 1E A5 22 AA 97 E8 73 87 3C 3C			
000016A0	20 36 35 20 34 31 20 43 36 20 41 30 20 46 38 0A 37 32 20 46 31 20 42 46 20 30 32 20 43 34 20 43 65 41 C6 A0 F8.72 F1 BF 02 C4 C			
000016C0	38 20 34 34 20 42 39 20 35 44 20 42 37 20 37 46 20 44 41 20 34 44 20 30 35 20 35 30 20 42 36 0A 8 44 B9 5D B7 7F DA 4D 05 50 B6.			
000016E0	37 31 20 37 44 20 35 46 20 35 41 20 35 34 20 45 32 20 46 46 20 41 35 20 31 36 20 37 42 20 34 39 71 7D 5F 5A 54 E2 FF A5 16 7B 49			

随机生成一组128位密钥对

然后使用样本中的硬编码的256位公钥生成相应的私钥

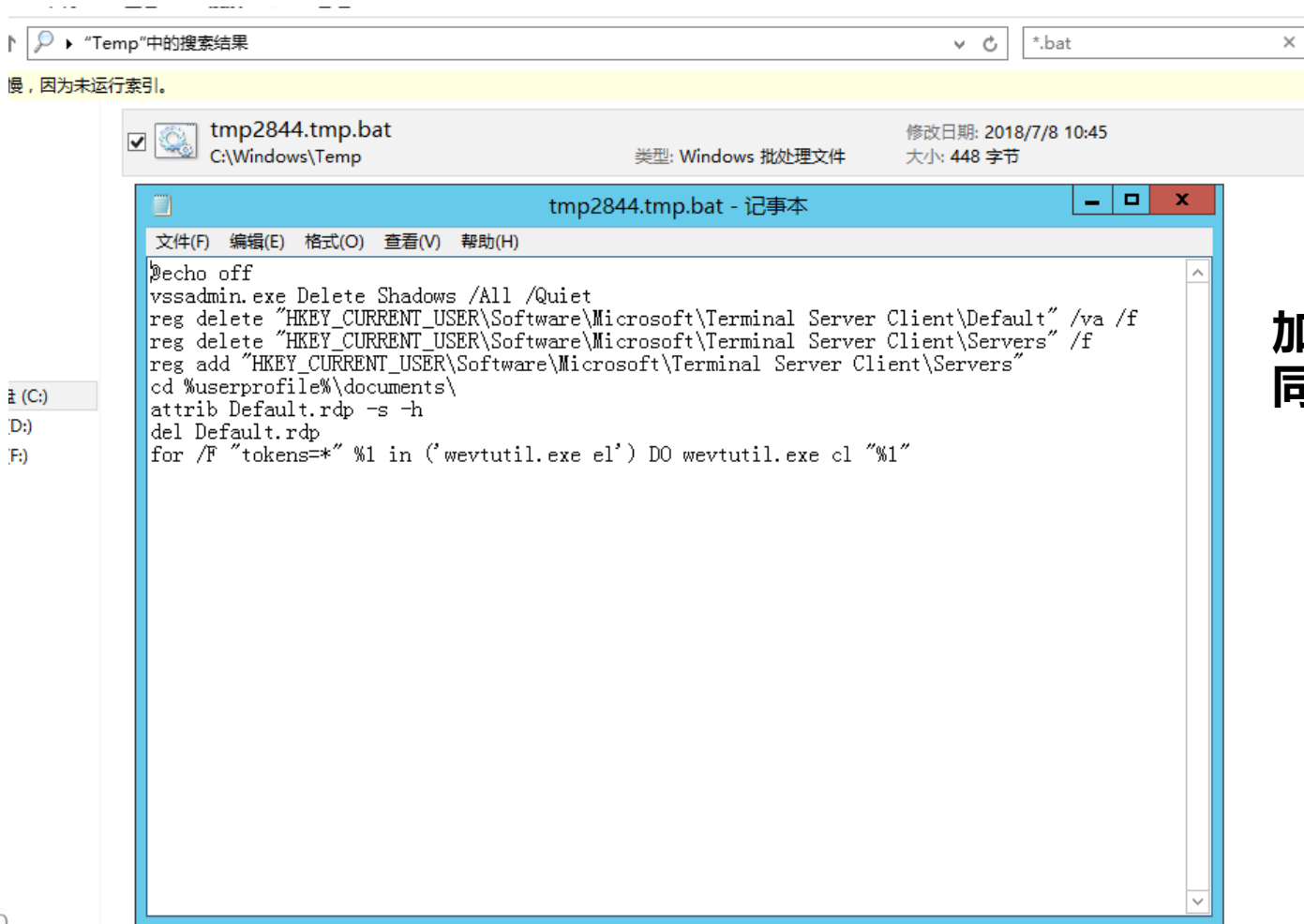
最后生成受害用户的个人ID序列号

遍历全盘，在排除样本中不加密文件夹列表后，使用随机生成的公钥加密其他所有文件

生成的个人ID序列号写入到加密文件末尾

取证要点

1.明确勒索病毒种类，分析恶意行为



加密文件操作完成后会删除卷影副本
同时删除远程桌面相关配置

取证要点

1.明确勒索病毒种类，分析恶意行为

K3InstallLog.log.ALCO	ALCO	1,648	2017-11-06 15:23:06	2017-11-06 1...	2018-07-08 10:13:32
F北京易商海泰克科技有限...	ALCO	756,229,552	2017-11-09 16:17:20	2017-11-09 1...	2018-07-08 10:13:32
FileCleanser.log.ALCO	ALCO	6,560	2017-11-06 15:23:05	2017-11-06 1...	2018-07-08 10:13:32
BOOTNXT.ALCO	ALCO	960	2012-07-26 16:10:25	2012-07-26 1...	2018-07-08 10:13:32
mchtype.lc.ALCO	ALCO	960	2017-10-30 11:56:52	2017-10-30 1...	2018-07-08 10:13:32
F北京易商海泰克科技有限...	ALCO	1,296	2017-11-09 16:17:35	2017-11-09 1...	2018-07-08 10:13:33
desktop.ini.ALCO	ALCO	1,120	2012-07-26 16:03:43	2012-07-26 1...	2018-07-08 10:13:33
F北京易商海泰克科技有限...	ALCO	432,211,376	2017-11-09 16:17:35	2017-11-09 1...	2018-07-08 10:13:33
F南华神州买卖提电子商务...	ALCO	430,122,416	2017-11-16 14:07:08	2017-11-16 1...	2018-07-08 10:13:33
F六微星数据科技有限公司	ALCO	1,000	2017-11-16 14:07:08	2017-11-16 1...	2018-07-08 10:13:33

2018.07.08 10 : 13 : 32-2018.07.08 10 : 45 : 16

\$RUQ5N93.rar.ALCO	ALCO	56,236,175	2017-11-16 14:06:06	2017-11-16 1...	2018-07-08 10:45:16
desktop.ini.ALCO	ALCO	1,088	2017-11-10 09:27:38	2017-11-10 0...	2018-07-08 10:45:16

取证溯源思路与方法



取证要点 1.明确勒索病毒种类，分析恶意行为

工具：IDA OD X32Dbg
沙箱分析

微步云沙箱
ThreatBook Cloud Sandbox

搜索或扫描 URL、文件 HASH(MD5/SHA1/SHA256)

上传文件 最新报告 API 个人中

创建进程
行为签名
释放文件
域名/IP

54 / 66

威胁情报IOC
行为签名
情报判定系统
基本信息
静态信息
执行流程
进程详情
运行截图
网络行为
释放文件

开始分析

alco.123.exe12333

msnbc news.url.alco
structuredquery.log.alco
windows live gallery.url.alco

读写ini文件
样本释放的文件
枚举文件和目录

https://www.virustotal.com/#/file/ad63a14fdc47914662ef92375e5d15948d8ce7a82ec15f10425a58089cf97663/detection

Search or scan a URL, IP address, domain, or file hash

EXE

54 / 66

54 engines detected this file

SHA-256 ad63a14fdc47914662ef92375e5d15948d8ce7a82ec15f10425a58089cf97663
File name alco.exe
File size 54 KB
Last analysis 2018-08-23 21:01:26 UTC
Community score -34

Detection Details Relations Behavior Community

Ad-Aware	Generic.Ransom.GlobelImposter.76C8...	AegisLab
AhnLab-V3	Trojan/Win32.FileCoder.R228072	ALYac
Arcabit	Generic.Ransom.GlobelImposter.76C8...	Avast
AVG	Win32:Malware-gen	Avira
AVware	Trojan.Win32.Generic!BT	Babable
Baidu	Win32.Trojan.WisdomEyes.16070401...	BitDefender
CAT-QuickHeal	Trojan.Genasom	Comodo
CrowdStrike Falcon	malicious_confidence_100% (D)	Cybereason
Cylance	Unsafe	DrWeb
Emsisoft	Generic.Ransom.GlobelImposter.76C8...	Endgame

ZERO TRUST SECURITY

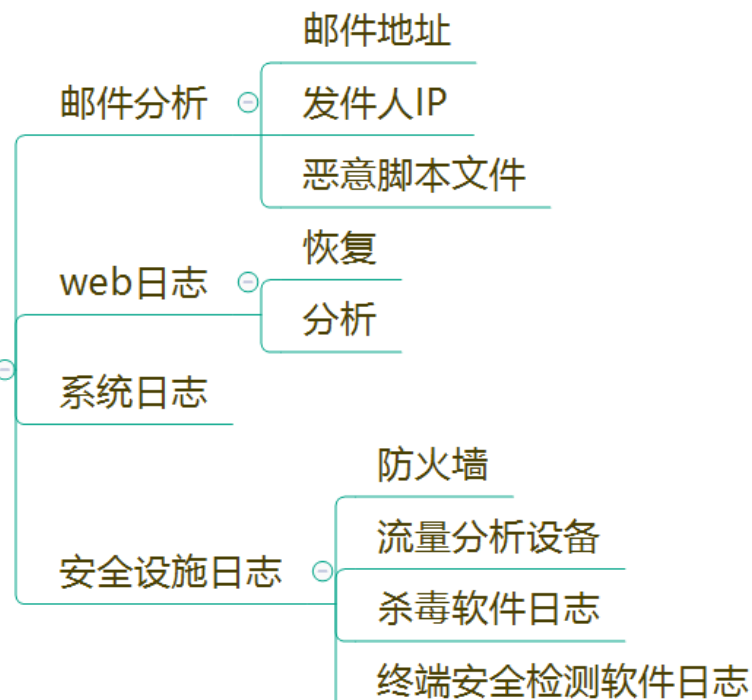
取证要点

2.确定投放路径：随机传播/蠕虫/定向勒索？

勒索软件投放



传播路径分析



取证溯源思路与方法

取证要点

2.确定投放路径：随机传播/蠕虫/定向勒索？

TCP	[*]:80	[*]:80	LISTENING
TCP	[*]:135	[*]:135	LISTENING
TCP	[*]:443	[*]:443	LISTENING
TCP	[*]:445	[*]:445	LISTENING
TCP	[*]:1801	[*]:1801	LISTENING
TCP	[*]:2103	[*]:2103	LISTENING
TCP	[*]:2105	[*]:2105	LISTENING
TCP	[*]:2107	[*]:2107	LISTENING
TCP	[*]:3389	[*]:3389	LISTENING
TCP	[*]:5985	[*]:5985	LISTENING
TCP	[*]:8088	[*]:8088	LISTENING
TCP	[*]:47001	[*]:47001	LISTENING
TCP	[*]:49152	[*]:49152	LISTENING
TCP	[*]:49153	[*]:49153	LISTENING
TCP	[*]:49154	[*]:49154	LISTENING
TCP	[*]:49155	[*]:49155	LISTENING
TCP	[*]:49162	[*]:49162	LISTENING
TCP	[*]:49175	[*]:49175	LISTENING
TCP	[*]:49178	[*]:49178	LISTENING
TCP	[*]:49179	[*]:49179	LISTENING
TCP	[*]:49184	[*]:49184	LISTENING
TCP	[*]:49296	[*]:49296	LISTENING
TCP	[*]:135	[*]:135	ESTABLISHED
TCP	[*]:49191	[*]:49191	ESTABLISHED
UDP	0.0.0.0:500	0.0.0.0:500	**
UDP	0.0.0.0:3389	0.0.0.0:3389	**
UDP	0.0.0.0:4500	0.0.0.0:4500	**
UDP	0.0.0.0:8088	0.0.0.0:8088	**
UDP	[*]:500	[*]:500	**
UDP	[*]:3389	[*]:3389	**
UDP	[*]:4500	[*]:4500	**
UDP	[*]:8088	[*]:8088	**

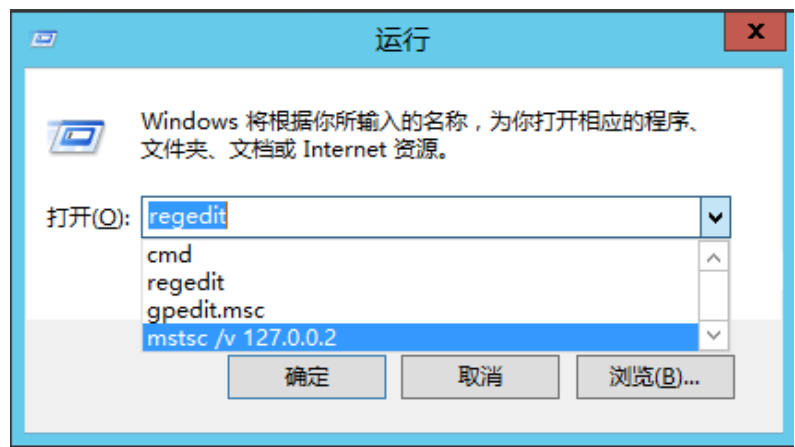
开放端口

应用程序	记录	系统	用户
ProcessHacker.exe	C:\Users\Administrator\Downloads\bild	Windows Server 2012...	Administrator
nl.exe	C:\Users\Administrator\Downloads	Windows Server 2012...	Administrator
DUBrute 2.1.exe	C:\Users\Administrator\Downloads\DB	Windows Server 2012...	Administrator
GNAdmin.exe	D:\Program Files (x86)\Kingdee\K3ERP	Windows Server 2012...	Administrator
UserClient.exe	D:\	Windows Server 2012...	Administrator

最近程序访问记录

序号	路径	类型
1	C:\Users\Administrator\Downloads\bild\alco.exe	*
2	C:\Users\Administrator\Downloads\results.txt	*
3	C:\Users\Administrator\Downloads\user.txt	*
4	C:\Users\Administrator\Downloads\ap.txt	*
5	C:\Users\Administrator\Downloads\DB2.1\pass.txt	*
6	C:\Users\Administrator\Downloads\DB2.1\user.txt	*
7	C:\Users\Administrator\Downloads\DB2.1\xp.txt	*
8	C:\Users\Administrator\Downloads\NN_Total+6_pass_09062018Part1.txt	*
9	C:\Users\Administrator\Downloads\pass.txt	*

最近打开保存的文档



最近执行的命令

取证要点

2.确定投放路径：随机传播/蠕虫/定向勒索？

 {1AC14E77-02E7-4E5D-B744-2EB1AE5198B7}\cmd.exe	2018-07-08 10:21:04	7
 C:\Users\Administrator\Downloads\bild\alco.exe	2018-07-08 10:16:03	1
 C:\Users\Administrator\Downloads\bild\PH new\ProcessHacker.exe	2018-07-08 10:12:08	1
 C:\Users\Administrator\Downloads\bild\NS.exe	2018-07-08 10:12:01	1
 C:\Users\Administrator\Desktop\clean.bat	2018-07-01 00:50:24	2
 C:\Users\Administrator\Downloads\nl.exe	2018-07-01 00:48:43	4
 C:\Users\Administrator\Downloads\DB2.1\DUBrute 2.1.exe	2018-07-01 00:30:10	4
 {F38BF404-1D43-42F2-9305-67DE0B28FC23}\regedit.exe	2018-06-30 23:53:49	4
 C:\Users\Administrator\Downloads\nasp.exe	2018-06-30 23:48:37	2

应用程序访问记录

使用的黑客工具：

ProcessHacker.exe NS.exe (7.08)

DUBrute2.1 nl.exe clean.bat (7.1)

取证溯源思路与方法



取证要点

2.确定投放路径：随机传播/蠕虫/定向勒索？

Hash	Type	Result
4695451af61d7ba20a0d1368f5da92c1	NTLM	kingdee

Hash	Type	Result
32ed87bdb5fdc5e9cba88547376818d4	NTLM	123456

4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	58885	2018-07-07 18:08:29	Administrator	10.240.83.23
4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	60402	2018-07-07 18:08:53	Administrator	10.240.83.23
4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	61908	2018-07-07 18:09:18	Administrator	10.240.83.23
4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	62649	2018-07-07 18:09:40	Administrator	10.240.83.23
4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	63422	2018-07-07 18:09:52	Administrator	10.240.83.23
4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	64184	2018-07-07 18:10:12	Administrator	10.240.83.23
4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	64879	2018-07-07 18:10:25	Administrator	10.240.83.23
4625	WIN-8FDHU07ILBR	PC-20180131SIUJ	10.238.151.142	65476	2018-07-07 18:10:38	Administrator	10.240.83.23

连接到本机远程桌面失败记录

事件	计算机	工作站	源网络地址	源端口	时间	登录帐户名	登录帐户域名	
1	4624	WIN-8FDHU07ILBR	00000000-0000-0000-...	-	%18	2018-07-12 16:20:31	ANONYMOUS L...	NT AUTHORITY
1	4624	WIN-8FDHU07ILBR	00000000-0000-0000-...	-	%18	2018-07-11 16:38:16	ANONYMOUS L...	NT AUTHORITY
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	fe80::99c5:f7aff56faf8	58544	2018-07-09 11:34:09	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	192.168.2.22	58542	2018-07-09 11:34:09	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	PC-20160401AMXC	fe80::d0ee:3df8:4a7b:b0b2	51887	2018-07-09 11:09:34	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	PC-20160401AMXC	192.168.2.21	51885	2018-07-09 11:09:31	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	PC-20160401AMXC	192.168.2.21	51883	2018-07-09 11:09:31	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	WIN-8FDHU07ILBR	192.168.2.27	0	2018-07-09 11:08:15	Administrator	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	WIN-8FDHU07ILBR	192.168.2.27	0	2018-07-09 10:51:54	Administrator	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160617TI	192.168.2.154	1643	2018-07-09 10:26:24	wanhu	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160617TI	192.168.2.154	1641	2018-07-09 10:26:23	wanhu	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	fe80::99c5:f7aff56faf8	56618	2018-07-09 10:26:10	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	192.168.2.22	56616	2018-07-09 10:26:09	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	fe80::99c5:f7aff56faf8	55434	2018-07-09 09:45:29	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	192.168.2.22	55432	2018-07-09 09:45:29	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	fe80::99c5:f7aff56faf8	55271	2018-07-09 09:38:19	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	192.168.2.22	55269	2018-07-09 09:38:19	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	PC-20160401AMXC	192.168.2.21	50420	2018-07-09 09:32:02	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	MS-20160413OQYI	fe80::a146:c808ed83:111d	50947	2018-07-09 09:30:38	Administrator	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	192.168.2.22	55433	2018-07-09 09:26:09	kingdee	WIN-8FDHU07ILBR
1	4624	WIN-8FDHU07ILBR	USER-20160328WWW	192.168.2.22	55433	2018-07-09 09:26:09	kingdee	WIN-8FDHU07ILBR

连接到本机远程桌面成功记录

取证要点

3.威胁情报分析溯源

事件	计算机	客户端名	客户端地址	时间	登录帐户名	登录账户域名	删除状态
4779	SLServer	7ACGPYHW2HDESSL	183.195.4.222	2018-07-12 22:26:49	SHSLUSER	SLSERVER	正常
4779	SLServer	7ACGPYHW2HDESSL	180.174.100.103	2018-07-13 10:24:15	SHSLUSER	SLSERVER	正常
4779	SLServer	7ACGPYHW2HDESSL	180.174.100.103	2018-07-13 16:57:49	SHSLUSER	SLSERVER	正常
4779	SLServer	7ACGPYHW2HDESSL	183.195.4.222	2018-07-14 08:25:24	SHSLUSER	SLSERVER	正常
4779	SLServer	7ACGPYHW2HDESSL	183.195.4.222	2018-07-14 12:55:27	SHSLUSER	SLSERVER	正常
4779	SLServer	7ACGPYHW2HDESSL	183.195.4.222	2018-07-15 14:34:41	SHSLUSER	SLSERVER	正常
4779	SLServer	7ACGPYHW2HDESSL	114.85.95.45	180.174.100.103			
4779	SLServer	7ACGPYHW2HDESSL	114.85.95.45	地理位置 中国 上海			
4779	SLServer	7ACGPYHW2HDESSL	114.85.95.45	微步标签 动态IP			
4779	SLServer	7ACGPYHW2HDESSL	114.85.95.45	用户标签 失陷主机(0) 爆破(0) 远控服务器(0) 撞库(0) 爬虫(0)			
4779	SLServer	7ACGPYHW2HDESSL	114.85.95.45	开放端口 0			
4779	SLServer	7ACGPYHW2HDESSL	114.85.95.45	IP上相关URL 0			
4779	SLServer	7ACGPYHW2HDESSL	114.85.95.45	首次域名指向			
4779	SLServer	7ACGPYHW2HDESSL	114.95.178.227	与该IP通信样本 0			
4779	SLServer	7ACGPYHW2HDESSL	114.95.178.227	反查域名 0			
4779	SLServer	7ACGPYHW2HDESSL	114.95.178.227	RDNS			
4779	SLServer	7ACGPYHW2HDESSL	114.95.178.227	ASN CHINANET-SH-AP China Telecom (Group), CN			
4779	SLServer	7ACGPYHW2HDESSL	114.95.179.186	API查询 加入监控 本地API 流量监测			
4779	SLServer	7ACGPYHW2HDESSL	114.95.179.178	情报聚合 5 IP反查 0 开放端口 0 可视化 数字签名 0 用户标签 0			
4779	SLServer	7ACGPYHW2HDESSL	114.95.179.178	微步情报 1 API接口			
4779	SLServer	7ACGPYHW2HDESSL	114.95.179.178	情报源 时间 情报内容 状态			
4779	SLServer	7ACGPYHW2HDESSL	183.195.4.222	ThreatBook Labs 2016-05-17 13:02:37 动态IP 有效			
4779	SLServer	7ACGPYHW2HDESSL	183.195.4.222	ThreatBook Labs 2016-07-08 02:57:25 僵尸网络 已过期			
4779	SLServer	7ACGPYHW2HDESSL	183.195.4.222	ThreatBook Labs 2016-07-07 15:48:51 垃圾邮件 僵尸网络 已过期			

异常IP 样本哈希

威胁情报关联分析
天际友盟
微步
360
其他等



取证要点

4. 加密虚拟货币追踪



13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb94
12t9YDPgwueZ9NyMgw519p7AA8isjr6SMw
115p7UMMngo1pMvkcHijcRdfJNXj6LrLn

如果勒索软件开发者用了交易所提供的地址, ...

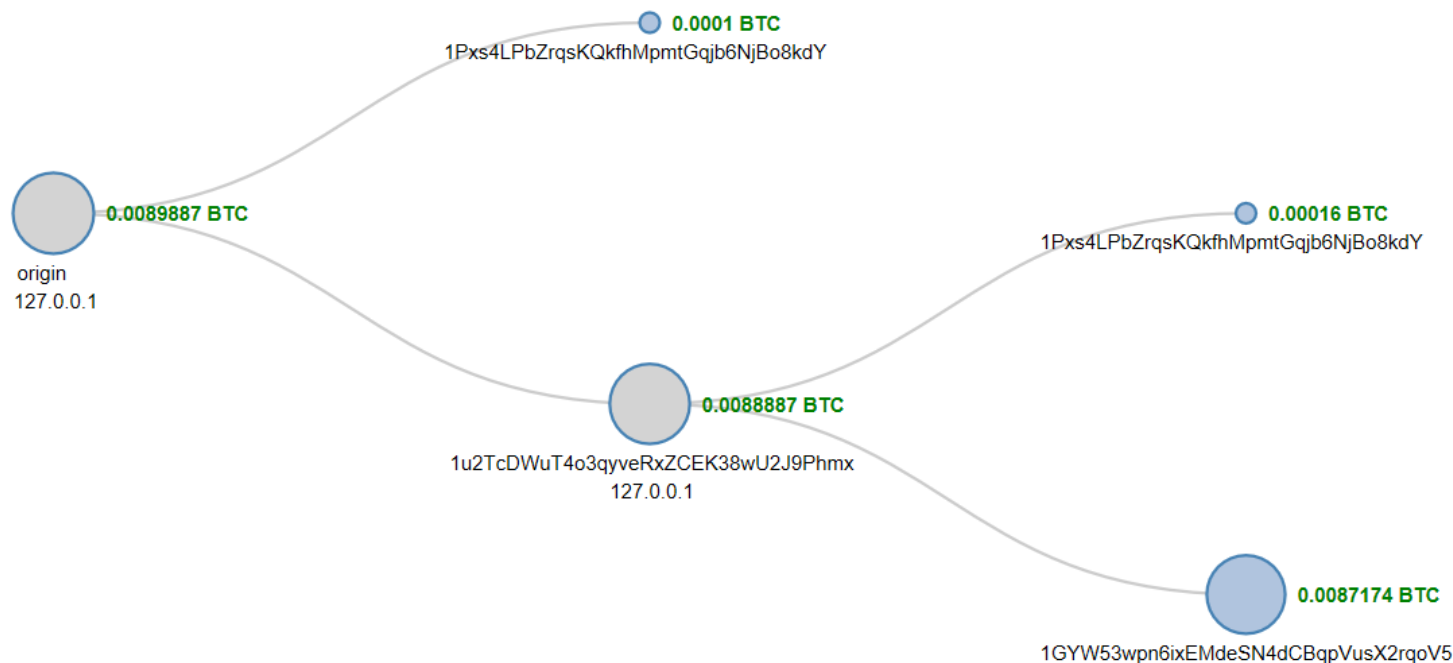


Bitcoin
Exchange

18NWHHyCkTfsDPQJaMu5uGhpviS87hWfWk
1Kz66SnzzmeBmKY3WpEzMKTrcBF2gpNQ44

取证要点

4. 加密数字货币追踪



公开信息：blockchain.info等
专门工具：maltgo/chianalysis

SilkRoad

比特币兑换是溯源的机会
比特币交易所一般需要提供：

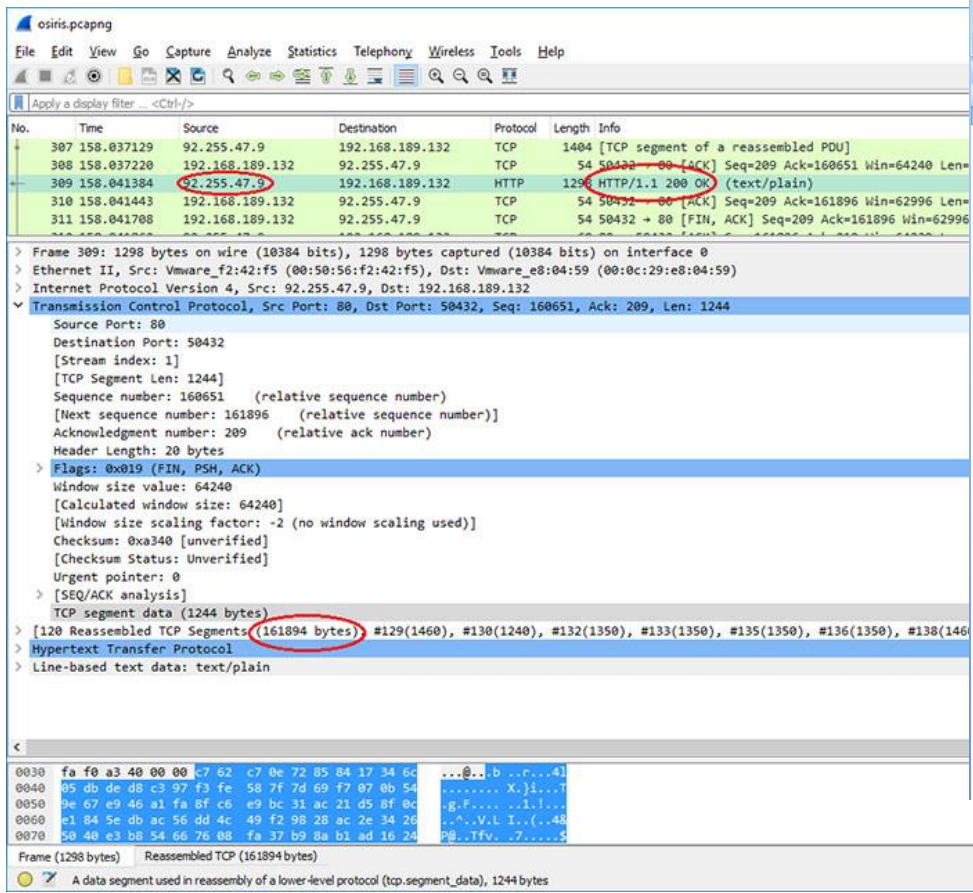
- 身份证或护照
- 地址证明
- 银行账户

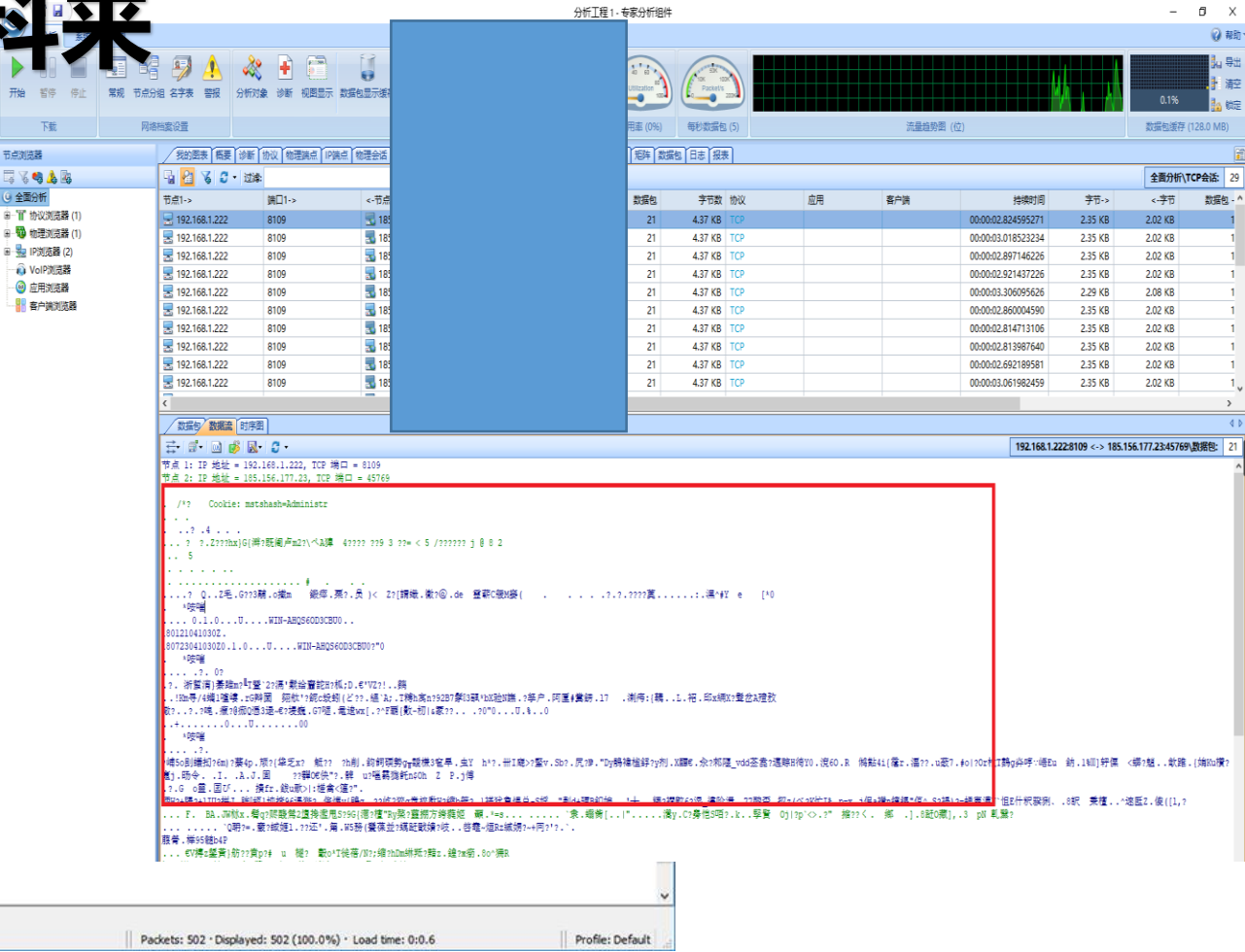
需要更加紧密的国际合作

取证要点

5.流量分析

WireShark/科来



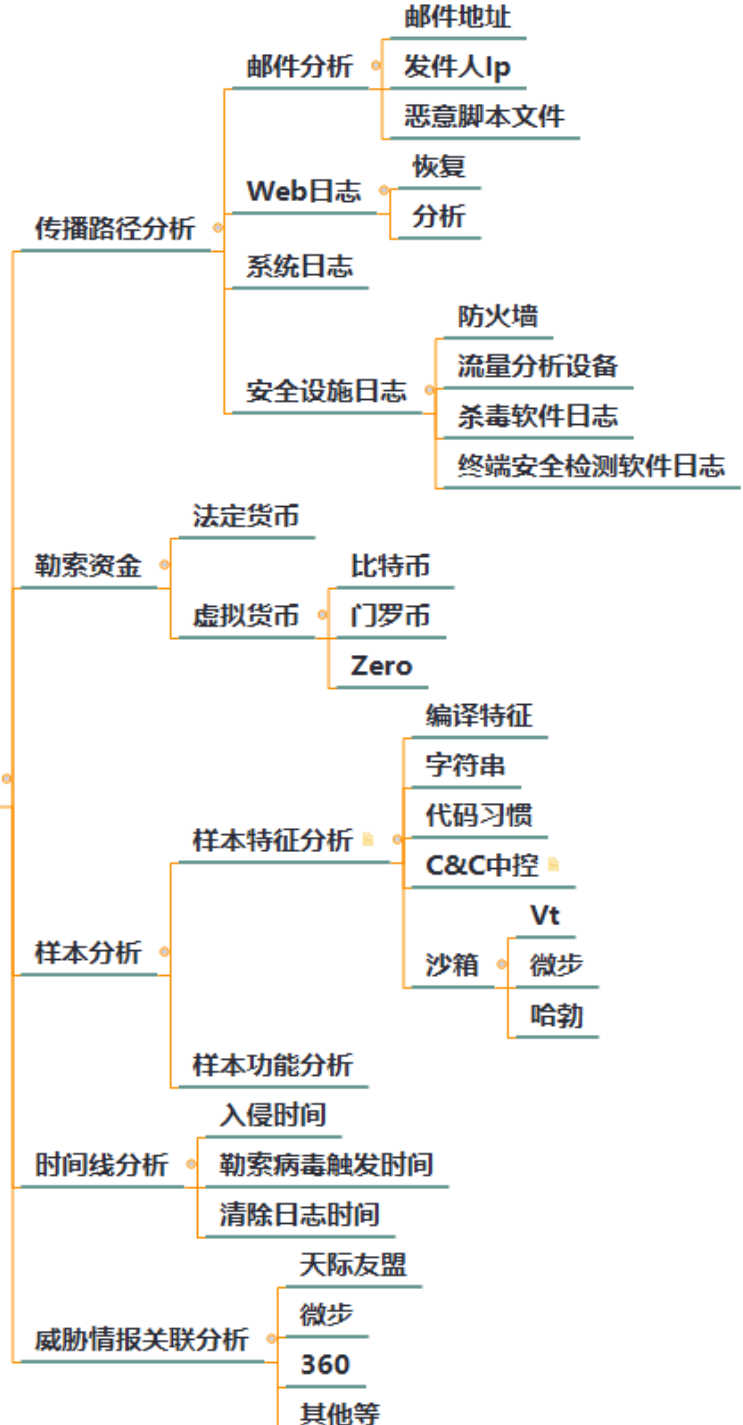


取证溯源思路与方法

取证要点



取证溯源



- 移动端、IOT
- 传播手段将更加多样化
- 定向攻击
- 隐藏犯罪手段
- 从勒索软件到挖矿木马

预防为主
备份备份备份

```
$ python jexboss.py

= Module readline not installed. The terminal will not support the arrow keys.

= Module readline not installed. The terminal will not support the arrow keys.

* --- JexBoss: Jboss verify and EXploitation Tool --- *
| * And others Java Deserialization Vulnerabilities * |
| @author: João Filho Matos Figueiredo |
| @contact: joaomatosf@gmail.com |
| @update: https://github.com/joaomatosf/jexboss |
#-----#

@version: 1.2.4

Examples: [for more options, type python jexboss.py -h]

For simple usage, you must provide the host name or IP address you
want to test [-host or -u]:

$ python jexboss.py -u https://site.com.br

For Java Deserialization Vulnerabilities in HTTP POST parameters.
This will ask for an IP address and port to try to get a reverse shell:

$ python jexboss.py -u http://vulnerable_java_app/page.jsf --app-unserialize
```

批量勒索挖矿常用漏洞利用工具Jexboss



ISC 互联网安全大会



360互联网安全中心

谢谢！

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

(原“中国互联网安全大会”)



请关注网安杂谈公众号